Security Testing

Introduction to the course

Welcome!
… *the university*

- University of Trento
- Department of Information Engineering and Computer Science (DISI)
- LM-18 Class of Master's degree program in Computer Science
- Master degree in Computer Sciences & EIT Digital Master Program, curriculum:
  - Information Science and Technology
  - ICT innovation
- Academic Year: 2024-2025

Welcome … *the course!*

Course: Security Testing

- Compulsory subjects, characteristic of the class
- Schedule:
  - Period: first semester of 2024 – 2025
  - Lesson period: September – December 2024
  - Exams: Jan./Feb. 2025, Jun./Jul. 2025, Sept. 2025
- Academic hours: 48h
  - Laboratories ~40% of hours
- 6 CFU(ECTS)
- Exam modality: in presence

Course	COMPUTER SCIENCE
Curriculum	Scienze e Tecnologie Informatiche
Course type	Two-year Master's degrees
Academic year	2024/2025
Year	1
Training activity type	Core
Scope	Information Technology
Language	ENGLISH
CFU	6 CFU
Didactic Activity Type	Lecture
Teaching period	First semester (from 09/09/2024 to 20/12/2024)

Schedule

Day	Time	Location and room
Monday	13.30 – 15.30	Povo 1, A206
Thursday	13.30 – 15.30	Povo 1, A205

Lecturers and Laboratories are not in a fixed day (… take your laptop with you)

- Moodle platform for course material
  - https://didatticaonline.unitn.it/dol/course/view.php?id=39258
- Esse3
  - https://www.esse3.unitn.it

*Remember **to register yourself** in the course on the Moodle platform!!!*

(news, course material, forum)

Registration for the exam

Schedule

Day	Time	Location and room
Monday	13.45 ~~13.30~~ – 15.30	Povo 1, A206
Thursday	13.30 – 15.30	Povo 1, A205

Lecturers and Laboratories are not in a fixed day (… take your laptop with you)

- Moodle platform for course material
  - https://didatticaonline.unitn.it/dol/course/view.php?id=39258
- Esse3
  - https://www.esse3.unitn.it

*Remember **to register yourself** in the course on the Moodle platform!!!*

(news, course material, forum)

Registration for the exam

Welcome … *the course!*

Lecturer: Alessandro Marchetto

- Researcher at UniTN
- ~10y experience in industry
- ~ 10y researcher in academia
- Ph.D. Computer science

Lecturer/Tutor: Rosmael Zidane Lekeufack Foulefack

- Phd student in Cybersecurity @ UniTN
- Expert in
  - AI for security
  - Vulnerability detection

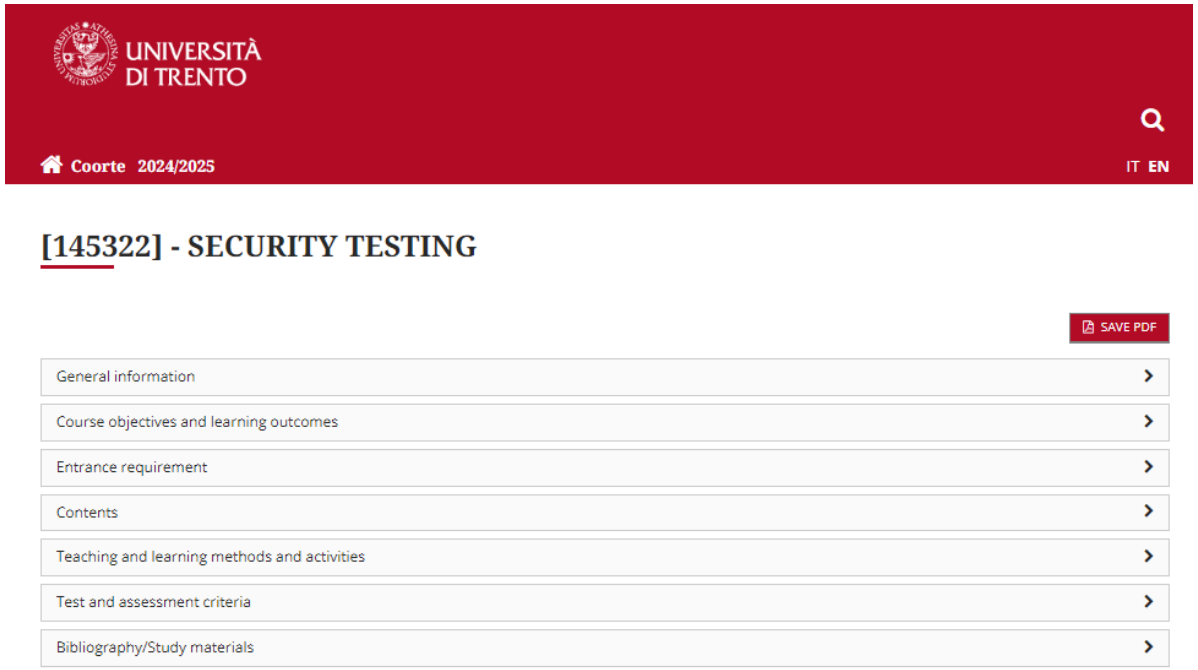
Outline

- **Course Syllabus**

Syllabus

Introduce the course in terms of:

- General information
- Learning objectives
- Expected learning outcomes
- Content
- Method
- Material
- Assessment method and criteria



Syllabus Security Testing 2024-2025

Learning Objectives and Outcomes

- Introductory class on Security Testing: principles, techniques and tools
- Make students familiar with fundamental principles of security testing, and provide them basic knowledge on existing methods, techniques and tools
  - Why security testing is essential to reveal security issues
  - How to apply security testing methods and techniques
  - State-of-the-art of existing tools
  - How to detect vulnerabilities in software projects

Highlights

- Security testing: Attacks models and taxonomies
- Software vulnerabilities
- Vulnerability detection
  - Static analysis
  - Dynamic analysis
  - Machine-learning methods

Expected outcome:

The student will be able to identify and detect in large systems the most frequent software vulnerabilities by applying existing solutions and tools

Course Content (not ordered)

Content by topics

Introduction to Security Testing

- Security testing overview
- Vulnerabilities, bugs, and secure coding

Course Content (not ordered)

Content by topics

Introduction to Security Testing

- Security testing overview
- Vulnerabilities, bugs, and secure coding

Context

- Vulnerability analysis
- Vulnerability rate
- Vulnerability repositories

Course Content (not ordered)

Content by topics

Introduction to Security Testing

- Security testing overview
- Vulnerabilities, bugs, and secure coding

Context

- Vulnerability analysis
- Vulnerability rate
- Vulnerability repositories

Vulnerabilities

- SQL injection
- XSS
- String format
- Buffer overflow
- Integer overflow
- Command injection
- Error handling
- Data storage
- CSRF
- …

Course Content (not ordered)

Content by topics

Introduction to Security Testing
- Security testing overview
- Vulnerabilities, bugs, and secure coding

Context
- Vulnerability analysis
- Vulnerability rate
- Vulnerability repositories

Vulnerabilities
- SQL injection
- XSS
- String format
- Buffer overflow
- Integer overflow
- Command injection
- Error handling
- Data storage
- CSRF
- …

Vulnerability detection
- Static analysis
  - Data-flow analysis
  - Static Taint analysis
  - Dependency analysis
- Dynamic analysis
  - Testing and Fuzzing
- Machine-learning analysis vulnerability detection

Course Content (not ordered)

Content by topics

Introduction to Security Testing
- Security testing overview
- Vulnerabilities, bugs, and secure coding

Context
- Vulnerability analysis
- Vulnerability rate
- Vulnerability repositories

Vulnerabilities
- SQL injection
- XSS
- String format
- Buffer overflow
- Integer overflow
- Command injection
- Error handling
- Data storage
- CSRF
- …

Vulnerability detection
- Static analysis
  - Data-flow analysis
  - Static Taint analysis
  - Dependency analysis
- Dynamic analysis
  - Testing and Fuzzing
- Machine-learning analysis vulnerability detection

Tools
- Static analysis
- Dynamic analysis
- ML-based analysis

Course Content (not ordered)

Content by topics

Introduction to Security Testing
- Security testing overview
- Vulnerabilities, bugs, and secure coding

Context
- Vulnerability analysis
- Vulnerability rate
- Vulnerability repositories

Vulnerabilities
- SQL injection
- XSS
- String format
- Buffer overflow
- Integer overflow
- Command injection
- Error handling
- Data storage
- CSRF
- …

Vulnerability detection
- Static analysis
  - Data-flow analysis
  - Static Taint analysis
  - Dependency analysis
- Dynamic analysis
  - Testing and Fuzzing
- Machine-learning analysis vulnerability detection

Tools
- Static analysis
- Dynamic analysis
- ML-based analysis

Advanced Topics (overview)
- Vulnerability scanning and pentest
- AI Testing
- Meet with security companies, if any

Course Content (not ordered)

Content by topics

Introduction to Security Testing
- Security testing overview
- Vulnerabilities, bugs, and secure coding

Context
- Vulnerability analysis
- Vulnerability rate
- Vulnerability repositories

Vulnerabilities
- SQL injection
- XSS
- String format
- Buffer overflow
- Integer overflow
- Command injection
- Error handling
- Data storage
- CSRF
- …

Vulnerability detection
- Static analysis
  - Data-flow analysis
  - Static Taint analysis
  - Dependency analysis
- Dynamic analysis
  - Testing and Fuzzing
- Machine-learning analysis vulnerability detection

Tools
- Static analysis
- Dynamic analysis
- ML-based analysis

Advanced Topics (overview)
- Vulnerability scanning and pentest
- AI Testing
- Meet with security companies, if any

… agreement is required?

Teaching method

The course is organized in:

Frontal lectures for the theoretical parts

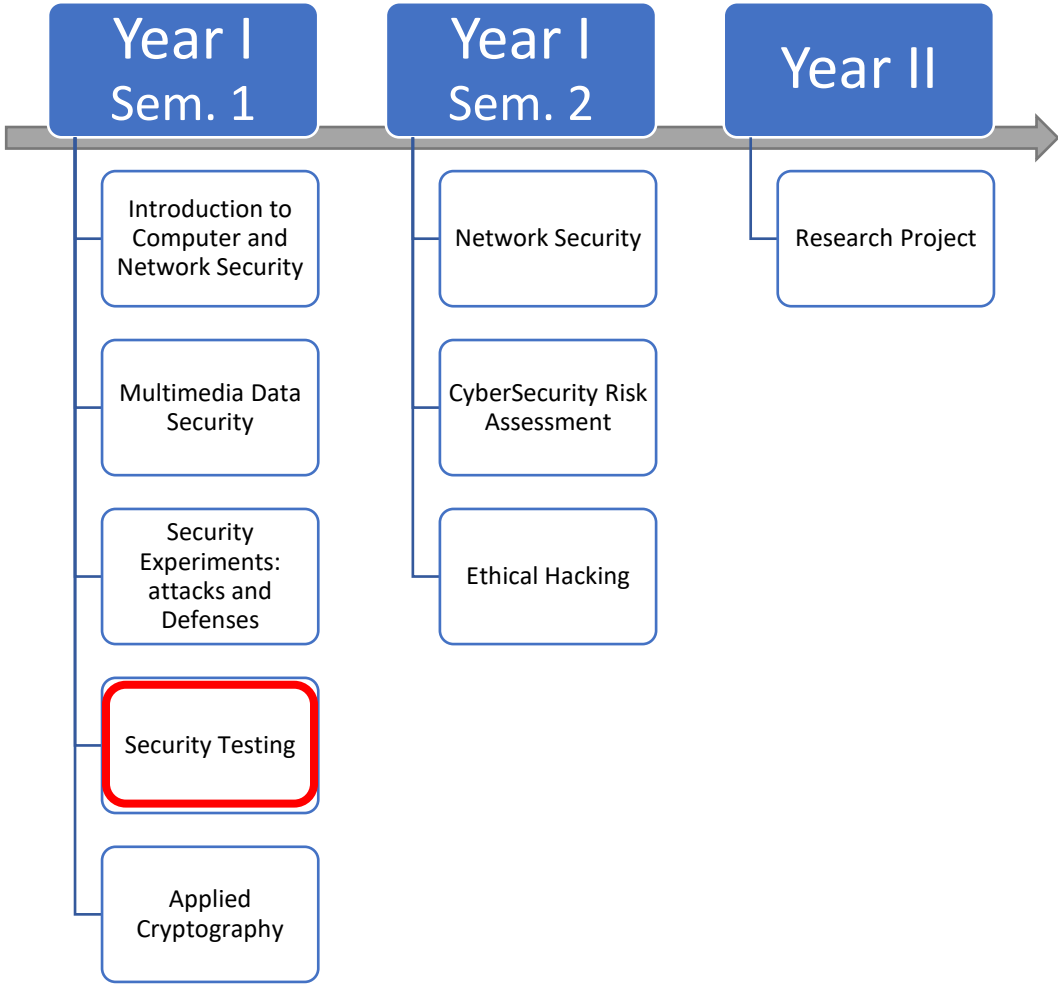
- Introduction of principles
- Methods and techniques
- Security issues and vulnerabilities
- Techniques to detect vulnerability in software systems
- Advanced topics (e.g., vulnerability scanning and pentest, vulnerability fixes, testing of AI software, meet with companies)

Laboratory sessions

- Learning by doing! … Practicing with methods, techniques and tools for testing and vulnerability detection by working alone and in groups

Prerequisites

- Basic knowledge about programming languages and software development capabilities is required
  - C/C++
  - Java
  - Python
  - Php
  - SQL
- Basic knowledge on cybersecurity and machine learning is helpful but not required



Material

- Slides and additional documents will be available on the course web site in Moodle
- Examples of code programs, the ones used in both lectures and laboratories, will be available on the course web site as well as additional examples will be also made available
- References to additional readings of interest for the students will be provided by the teacher

Assessment methods and criteria

Exam sessions: January/February 2025, June/July 2025, September 2025

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send before the written exam)

Exam

- The two parts even in distinct exam sessions
- No fixed or constrained execution order for the two parts
- The grade is expressed in /30
- Both parts are passed with at least 18 in each part
- The final grade is the average score of the two parts

$Grade_{overall} = 0.65 * grade_{written} + 0.35 * grade_{project} + extra_point/s$

Notes:

1. A simulation of the written test will be organized at the end of the course (written test)
   - **Nov.25** (to be confirmed, room availability)
2. [To be confirmed-NEW] Three in-course laboratories will be devoted to work on the exam project
   - Sept.24, Oct.24, Nov.21, (to be confirmed)
3. [To be confirmed] (from 2023-2024): we can have two laboratories with exercises or homework during the course for an extra point/s
   - Oct. 28 and Nov. 4 (to be confirmed)

Assessment methods and criteria

Exam sessions: January/February 2025, June/July 2025, September 2025

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send before the written exam)

Exam

- The two parts even in distinct exam sessions
- No fixed or constrained execution order for the two parts
- The grade is expressed in /30
- Both parts are passed with at least 18 in each part
- The final grade is the average score of the two parts

$Grade_{overall} = 0.65 * grade_{written} + 0.35 * grade_{project} + extra_point/s$

Notes:

1. A simulation of the written test will be organized at the end of the course (written test)
   - **Nov.25** (to be confirmed, room availability)
2. [To be confirmed-NEW] Three in-course laboratories will be devoted to work on the exam project
   - Sept.24, Oct.24, Nov.21, (to be confirmed)
3. [To be confirmed] (from 2023-2024): we can have two laboratories with exercises or homework during the course for an extra point/s
   - Oct. 28 and Nov. 4 (to be confirmed)

… agreement is required?

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send before the written exam)

1/2

Project topic

- Typically: test of a selected application
- The project material: report of the testing activities on a PDF file and related XLS file with details

Submission

- The project material has to be submitted at the latest one week before the exam session. For instance,
  - Exam: Jan.24, 2025 - Submission deadline: Jan.17, 2025 (AoE) - Strict deadline!
  - Exam: Feb.21, 2025 - Submission deadline: Feb.14, 2025 (AoE) - Strict deadline!

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send before the written exam)

2/2

Project topic

- Typically: test of a selected application
- The project material: report of the testing activities on a PDF file and related XLS file with details

Submission

- The project material has to be submitted at the latest one week before the exam session. For instance,
  - Exam: Jan.24, 2025 - Submission deadline: Jan.17, 2025 (AoE) - Strict deadline!
  - Exam: Feb.21, 2025 - Submission deadline: Feb.14, 2025 (AoE) - Strict deadline!

Submission rules

- The project material must be submitted by groups of maximum two students each one (but the task conducted by each student must be specified).
- The project material can be submitted only two (also non-consecutive) times (in any case, if it is not sufficient or for increasing the grade).
- The project material evaluated as not sufficient (grade <=18) can be resubmitted one time (up to a maximum of 2 submissions per year).
- In case the project material non-sufficient (grade <= 18) for 2 times, the project cannot be resubmitted, a different project has to be arranged.
- In case of resubmission of the project material previously evaluated as sufficient (grade >= 18), the resubmission cancels the previous obtained score.
- In case resubmission with positive final grade (>= 18), the project cannot be resubmitted, a different project has to be arranged with the teacher if the students wants to increase the score (but the obtained grade is cancelled).
- In case resubmission, a clear delta between the second submission and the first one must exists, otherwise the final score will be decreased of 1.
- The project evaluated as sufficient (>= 18) is valid for the academic year for two written (theoretic) exams evaluated as sufficient (grade of the written test >= 18)

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send one week before the official exam date)

2/2

○ In-course submission (***NEW*** - *from academic year 2024/2025*)

- Not mandatory
- The project material must be submitted by groups of maximum two students each one (but the task conducted by each student must be specified).
- Project submission splitted into 3(+1) milestones during the course
  - Goal: submitting the project material in three parts, according to the advancement of the course
  - The (+1) is the revision milestone, i.e., in which only a revision of the already submitted material will be allowed (goal: improving the quality)
  - Schedule Tentative: Oct.21, Nov.14, Dec.9, Dec.19 (to be confirmed)
- If only one/two milestones are submitted, then the project is not sufficient (the grade is given only once for the whole project)
- In case of: (a) no submission or (b) partial submission (e.g., only one/two milestones), the student can resubmit in January or in any other official exam session, but in case (b), the in-course submission must be withdrawn before the last in-course milestone (i.e., Dec.19 -to be confirmed)
- This “in-course submission” counts 1 as project submission, so in case of a sufficient project score (grade >=18), only another resubmission is allowed
- In case of sufficient project evaluation (grade >=18), the grade will be valid for the academic year for two written (theoretic) test passed with a sufficient score
- The “in-course submission” can be withdrawn before the last in-course milestone (i.e., Dec.19 -to be confirmed)
- As usual, the project grade will be communicated after the exam session

This is the first tentative, in case of problems or disagreement we have to cancel the in-course submission

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send one week before the official exam date)

2/2

○ In-course submission (*NEW* - *from academic year 2024/2025*)

- Not mandatory
- The project material must be submitted by groups of maximum two students each one (but the task conducted by each student must be specified).
- Project submission splitted into 3(+1) milestones during the course
  - Goal: submitting the project material in three parts, according to the advancement of the course
  - The (+1) is the revision milestone, i.e., in which only a revision of the already submitted material will be allowed (goal: improving the quality)
  - Schedule Tentative: Oct.21, Nov.14, Dec.9, Dec.19 (to be confirmed)
- If only one/two milestones are submitted, then the project is not sufficient (the grade is given only once for the whole project)
- In case of: (a) no submission or (b) partial submission (e.g., only one/two milestones), the student can resubmit in January or in any other official exam session, but in case (b), the in-course submission must be withdrawn before the last in-course milestone (i.e., Dec.19 -to be confirmed)
- This “In-course submission” counts 1 as project submission, so in case of a sufficient project score (grade >=18), only another resubmission is allowed
- In case of sufficient project evaluation (grade >=18), the grade will be valid for the academic year for two written (theoretic) test passed with a sufficient score
- The “in-course submission” can be withdrawn before the last in-course milestone (i.e., Dec.19 -to be confirmed)
- As usual, the project grade will be communicated after the exam session

This is the first tentative, in case of problems or disagreement we have to cancel the in-course submission

Each session is composed of two parts (about 65% + 35%)

- A written test with questions and exercises to assess the acquired theoretical competence (Time: max 2h)
- A written report on a project (to send one week before the official exam date)

2/2

○ In-course submission (*NEW* - *from academic year 2024/2025*)

- Not mandatory
- The project material must be submitted by groups of maximum two students each one (but the task conducted by each student must be specified).
- Project submission splitted into 3(+1) milestones during the course
  - Goal: submitting the project material in three parts, according to the advancement of the course
  - The (+1) is the revision milestone, i.e., in which only a revision of the already submitted material will be allowed (goal: improving the quality)
  - Schedule Tentative: Oct.21, Nov.14, Dec.9, Dec.19 (to be confirmed)
- If only one/two milestones are submitted, then the project is not sufficient (the grade is given only once for the whole project)
- In case of: (a) no submission or (b) partial submission (e.g., only one/two milestones), the student can resubmit in January or in any other official exam session, but in case (b), the in-course submission must be withdrawn before the last in-course milestone (i.e., Dec.19 -to be confirmed)
- This "In-course submission" counts 1 as project submission, so in case of a sufficient project score (grade >=18), only another resubmission is allowed
- In case of sufficient project evaluation (grade >=18), the grade will be valid for the academic year for two written (theoretic) test passed with a sufficient score
- The "in-course submission" can be withdrawn before the last in-course milestone (i.e., Dec.19 -to be confirmed)
- As usual, the project grade will be communicated after the exam session

This is the first tentative, in case of problems or disagreement we have to cancel the in-course submission

Interactions with the teacher/s

- Ask questions before/after/during the lectures, laboratories, and breaks
- Ask for 1-to-1 meetings only for (personal) problems and clarifications
- Ask questions via email: try to limit yourself to relevant questions, otherwise we will be not able to answer at all!
  - E.g.,
    - Meeting for clarifications
    - Alerts about mistakes and problems with the material
    - Alerts about problems such as time overlaps
    - Alerts about specific and personal problems of the student (e.g., working student, etc.)
- Please, for any contact with us it is mandatory to use the email address from UniTN ***name.surname@studenti.unitn.it***

Ethical Acceptance

- You are bound by the terms and conditions of this course
  - You try testing methods and technologies only in the lab (or your PC)
  - You are not allowed to apply the methods, technologies and attacks to a currently working system
  - You are not allowed to discuss your homework with third-parties or colleagues
  - You are not allowed to pass any material of the course to

- Any use outside the agreed framework of the course may be penalty relevant (in some cases also a crime)

A note on plagiarism

Total or partial plagiarism is forbidden!

- Exam tests
- Homeworks (if any)
- Exercises
- Projects
- …

"*I took this text from a colleague of mine*" No! … no reuse of material produced by other colleagues is allowed

In case of plagiarism, you will fail the class.

Beyond the course

The Security Group @ DISI offers support for:

- Internal internship/stage
- Thesis
- Course projects (6 credits)
- Research projects (12 credits)
- Company internships and stages